Normativas, Regulaciones y Legislación

Manuel Jesús Rivas Sández

mrivas@iesrafaelalberti.es

@CyberAlberties

ÍNDICE

OBJETIVOS 3

INTRODUCCIÓN 3

PROTECCIÓN DE DATOS PERSONALES 3

LODP Y RGPR 4

- LEY ORGÁNICA DE PROTECCIÓN DE DATOS 4
  - OBLIGACIONES 5
- REGLAMENTO DE DESARROLLO DE LA LODP 8
  - OBLIGACIONES 8
  - NIVELES DE SEGURIDAD 9
  - INFRACCIONES Y SANCIONES 12
- REGLAMENTO GENERAL DE PROTECCIÓN DE DATOS 14
  - OBLIGACIONES 14
  - IMPLANTACIÓN DEL RGPD 18
- LEY ORGÁNICA DE PROTECCIÓN DE DATOS Y GARANTÍA DE LOS DERECHOS DIGITALES 20
  - OBLIGACIONES 20
  - GARANTÍAS DE DERECHOS DIGITALES 22
  - REGIMEN SANCIONADOR 23
  - DISPOSICIONES ADICIONALES 25

LSSI-CE Y E-PRIVACY 26

- LEY DE SERVICIOS DE LA SOCIEDAD DE LA INFORMACIÓN Y DE COMERCIO ELECTRÓNICO 27
- E-PRIVACY 29
  - NOVEDADES 30

NORMATIVAS DE INTERÉS 31

- LEY DE PROTECCIÓN INTELECTUAL (LPI) 31
- ESQUEMA NACIONAL DE SEGURIDAD (ENS) 32

RESUMEN 33

ACTIVIDADES 33

GLOSARIO 33

BIBLIOGRAFÍA 33

OBJETIVOS

- Conocer y aplicar las leyes aplicables a la protección de datos personales
- Conocer y aplicar la ley LSSI-CE
- Conocer y aplicar el reglamento E-PRIVACY

1. INTRODUCCIÓN

Cuando hablamos de legislación informática, nos referimos a los acuerdos y las leyes aprobadas que regulan el uso de la información que se encuentra en la internet, dispositivos electrónicos y cualquiera de los medios digitales junto con los delitos que se cometen por el uso indebido de estos, además, observa todo lo relativo a la propiedad intelectual y derechos de autor.

Hablábamos en unidades anteriores, de las consecuencias acarreadas por los avances tecnológicos e Internet en el ámbito jurídico y la necesidad de replantear –o revisar– el contenido de algunos bienes jurídicos. No podemos abordar a indagar en algunas de ellas para que veáis cómo la realidad tecnológica incide y modifica nuestro ordenamiento jurídico y nuestro derecho.

- **La redefinición de algunos derechos**
- **La aparición de nuevos intereses o valores**

2. PROTECCIÓN DE DATOS PERSONALES

Durante las unidades 1 y 2 hemos comprobado el valioso papel que adquiere la información para las empresas. Y a través de las guías de buenas prácticas y la adecuación de metodologías de gestión de riesgos hemos llegado a entender cómo orquestar los ciclos y procesos de una organización para que pueda adquirir conciencia de seguridad y anticipar un correcto tratamiento de los riesgos de sus activos. Sin embargo, todavía no hemos evaluado las obligaciones y responsabilidades en el ámbito legal que las empresas deben instaurar y garantizar. Teniendo en cuenta además el papel tan sumamente importante que tiene a día de hoy la información privada y sensible de los individuos.

No cabe duda que la protección de datos personales siempre ha tenido una consideración sumamente relevante en el panorama, tanto nacional como internacional. Prácticamente desde los comienzos, la cultura de la información adquirió consciencia sobre la necesidad de salvaguardar y garantizar la protección de los datos personales, siendo a día de hoy un derecho fundamental de todos los ciudadanos de la Unión Europea. Es indudable que existen un gran número de riesgos potenciales, tales como la divulgación no autorizada, la suplantación de identidad o el abuso en línea. De hecho, la Constitución Española incide en el factor de la protección de datos en el artículo 18 sobre la intimidad de las personas:

18.1. Se garantiza el derecho al honor, a la intimidad personal y familiar y a la propia imagen.

18.4. La Ley limitará el uso de la Informática para garantizar el honor y la intimidad personal y familiar de los ciudadanos y el pleno ejercicio de sus derechos.

En España es la Agencia Española de Protección de Datos (AEPD), la autoridad pública independiente encargada de velar por la privacidad y la protección de datos de los ciudadanos. Esta agencia pone un esfuerzo constante en que los ciudadanos conozcan sus derechos, posibilitando y facilitando que puedan ejercerlos y, por otro, que los sujetos/empresas obligados a cumplir con la normativa, tengan a su disposición un instrumento ágil que les facilite el cumplimiento de la misma. La AEPD también se encarga de realizar estudios y campañas de concienciación para advertir de los riesgos del uso de nuevas tecnologías sin las necesarias medidas de seguridad y sin que el usuario posea cierta educación y cultura relativas a la gestión de su información privada.

3. LODP Y RGPR

El Reglamento General de Protección de Datos (RGPD) [General Data Protection Regulation – GDPR] es el nuevo reglamento relativo al tratamiento de datos personales y a la libre circulación de estos datos para la protección de las personas físicas y sus derechos.

El RGPD entró en vigor el 25 de mayo de 2016 y fue de aplicación el 25 de mayo de 2018. Período de tiempo durante el cual las empresas, organizaciones, organismos y las instituciones han ido adaptándose para su cumplimiento. En el caso de España, la actual RGPD derogó parcialmente la Ley Orgánica de Protección de Datos de Carácter Personal (**LOPD**) aprobada por las Cortes Generales mediante Ley Orgánica 15/1999 el 13 de diciembre de 1999 y cuyo **Reglamento de Desarrollo de la LODP** fue aprobado en el Real Decreto 1720/2007, el 21 de diciembre de 2007.

Pese a esta sustitución, la LOPD era un reglamento muy conciso y maduro al respecto de la protección de datos personales, por lo que todas aquellas empresas que cumpliesen con dicha normativa, han podido incorporar los cambios y requisitos exigidos por la RGPD de manera mucho más fácil y cómoda. No ha sido en diciembre de 2018 cuando en respuesta al RGDP se aprueba en España la Ley Orgánica de Protección de Datos y Garantías de Derechos Digitales (LOPDGDD) diseñada para proporcionar entrada en el ordenamiento jurídico interno al RGPD, pero, además, diversas consideraciones de interés que no habían sido abordadas explícitamente por dicho reglamento han sido añadidas generando no poca polémica.

Sin embargo, por el período tan reducido que lleva en vigor la LOPDGDD y que muchas empresas, como siempre, no se han preparado y les ha cogido de forma inesperada, es importante entender la regulación que existía previa al RGPD y destacar las novedades incorporadas. Así pues, repasemos el

reglamento de la LOPD para, a continuación, entender las mejoras y cambios introducidos por la RGPD y sus consecuencias para las empresas y organizaciones. Y finalizaremos con el LOPDGDD y sus consideraciones más recientes que a todos los efectos establecen el marco jurídico aplicable a nuestra actividad diaria actual.

3.1. LEY ORGÁNICA DE PROTECCIÓN DE DATOS

El objeto de LOPD es garantizar y proteger, en lo que concierne al tratamiento de los datos personales, las libertades públicas y los derechos fundamentales de las personas físicas, especialmente con la finalidad de preservar el honor, intimidad personal y familiar y el pleno ejercicio de los derechos personales frente a su alteración, pérdida, tratamiento o acceso no autorizado. Todo esto es aplicable a los datos de carácter personal registrados en cualquier tipo de soporte físico susceptible de ser tratado (ya sea informático o no).

Por lo tanto, bajo la aplicación de la LOPD existen una serie de obligaciones para aquellas entidades públicas o privadas que posean ficheros con datos de carácter personal. Además, el **Reglamento de Desarrollo** establece la obligación para todas las organizaciones de poner en marcha diversas medidas destinadas a garantizar la protección de dichos datos, afectando a sistemas informáticos, medios de almacenamiento, procedimientos operativos, etc.

3.1.1. OBLIGACIONES

De cara a no exceder el ámbito del presente curso, repasamos aquellas obligaciones que mayor relación guardan respecto a la seguridad de la información y que mayor incidencia y repercusiones puedan provocar en el desempeño de actividades tecnológicas.

ARTÍCULO 4. CALIDAD DE LOS DATOS

Los datos de carácter personal sólo se podrán recoger para su tratamiento, cuando sean adecuados, pertinentes y no excesivos en relación con el ámbito y el propósito y las finalidades determinadas, explícitas y legítimas para las que se hayan obtenido. No se podrán recoger para finalidades incompatibles con aquellas para las que los datos hubieran sido recogidos. No se considerará incompatible el tratamiento posterior de éstos con fines históricos, estadísticos o científicos. Los datos deben ser exactos y actualizados, caso contrario deben ser cancelados y sustituidos. Los datos de carácter personal serán cancelados cuando hayan dejado de ser necesarios o pertinentes para la finalidad para la cual hubieran sido recabados o registrados. Se prohíbe la recogida de datos por medios fraudulentos, desleales o ilícitos.

ARTÍCULO 5. DERECHO DE INFORMACIÓN EN LA RECOGIDA DE DATOS.

Los interesados a los que se soliciten datos personales deberán ser previamente informados de modo expreso, preciso e inequívoco de la existencia de un fichero o tratamiento de datos de

carácter personal, de la finalidad de la recogida de éstos y de los destinatarios de la información, así como del responsable de su tratamiento, debiendo existir uno incluso si el destinatario no está en territorio de la Unión Europea. Además, de la posibilidad de ejercitar los derechos de **acceso, rectificación, cancelación y oposición** (**ARCO**). Cuando se utilicen cuestionarios u otros impresos para la recogida, figuran en los mismos, en forma claramente legible, las advertencias a que se refiere a dichos derechos.

A partir de este artículo cobra relevancia el elemento del **fichero**, que es todo conjunto organizado de datos de carácter personal, cualquiera que fuere la forma o modalidad de su creación, almacenamiento, organización y acceso. De aquí en adelante los datos personales y sus respectivas menciones al tratamiento aludirá a ficheros cuyo contenido es el conjunto de datos a tratar.

ARTÍCULO 6. CONSENTIMIENTO DEL AFECTADO.

El tratamiento de los datos de carácter personal requerirá el consentimiento inequívoco del afectado, salvo que la ley disponga otra cosa. En algunos casos, no será preciso el consentimiento, por ejemplo, cuando los datos de carácter personal se recojan para el ejercicio de las funciones propias de las Administraciones públicas; cuando sean necesarias para el mantenimiento o cumplimiento de un contrato o precontrato de una relación de negocio, laboral o administrativa; o cuando el tratamiento de los datos tenga por finalidad proteger un interés vital del interesado. Este consentimiento podrá ser revocado cuando exista causa justificada para ello y no se le atribuyen efectos retroactivos.

ARTÍCULO 7. DATOS ESPECIALMENTE PROTEGIDOS.

Nadie podrá ser obligado a declarar sobre su ideología, religión o creencias. Sólo con el consentimiento expreso y por escrito del afectado podrán ser objeto de tratamiento estos datos mencionados. Se exceptúan los ficheros mantenidos por entidades como partidos políticos, sindicatos, iglesias, asociaciones y otras entidades sin ánimo de lucro, cuya finalidad sea política, filosófica, religiosa o sindical, en cuanto a los datos relativos a sus asociados o miembros, sin perjuicio de que la cesión de dichos datos precisará siempre el previo consentimiento del afectado.

Los datos de carácter personal que hagan referencia al origen racial, a la salud y a la vida sexual sólo podrán ser recabados, tratados y cedidos cuando, por razones de interés general, así lo disponga una ley o el afectado consienta expresamente. Salvo que dicho tratamiento resulte necesario para la prevención o para el diagnóstico médico, la prestación de asistencia sanitaria o tratamientos médicos o la gestión de servicios sanitarios. Además, se permite el tratamiento para salvaguardar el interés vital del afectado o de otra persona, en el supuesto de que el afectado esté física o jurídicamente incapacitado para dar su consentimiento.

ARTÍCULO 9. SEGURIDAD DE LOS DATOS.

El responsable del fichero, y, en su caso, el encargado del tratamiento deberá adoptar las medidas de índole técnica y organizativas necesarias que garanticen la seguridad de los datos de carácter personal y eviten su alteración, pérdida, tratamiento o acceso no autorizado, habida cuenta del estado de la tecnología, la naturaleza de los datos almacenados y los riesgos a que están expuestos, ya provengan de la acción humana o del medio físico o natural. No se registrarán datos de carácter personal en ficheros que no reúnan las condiciones que se determinen por vía reglamentaria con respecto a su integridad y seguridad y a las de los centros de tratamiento correspondientes, según sean locales, equipos, sistemas o programas.

ARTÍCULO 10. DEBER DE SECRETO.

El responsable del fichero y quienes intervengan en cualquier fase del tratamiento de los datos de carácter personal están obligados al secreto profesional respecto de los mismos y al deber de guardarlos, obligaciones que se seguirán garantizando aun después de finalizar la relación con el titular del fichero o, en su caso, con el responsable del mismo.

ARTÍCULO 11. COMUNICACIÓN DE DATOS.

Los datos de carácter personal sólo podrán ser comunicados a un tercero para el cumplimiento de fines directamente relacionados con las funciones legítimas del cedente y del cesionario con el previo consentimiento del interesado. Aunque dicho consentimiento no será necesario cuando lo autorice una ley; los datos estén accesibles públicamente; cuando forme parte de una relación jurídica y los datos sean obligatorios; cuando se cedan a distintas entidades o instituciones como el Defensor del Pueblo, Tribunales o equivalentes; cuando sean datos relativos a salud y sean necesarios para una urgencia médica; o situaciones similares.

Será nulo el consentimiento para la comunicación de los datos de carácter personal a un tercero, cuando la información que se facilite al interesado no le permite conocer su finalidad.

ARTÍCULO 12. ACCESO A LOS DATOS POR CUENTA DE TERCEROS.

El tratamiento de datos por parte de un tercero debe estar regulado mediante un contrato que tendrá que constar por escrito o en alguna u otra forma que permita acreditar su celebración y contenido, estableciéndose expresamente que el encargado del tratamiento únicamente tratará los datos conforme a las instrucciones del responsable del tratamiento, que no los aplicará o utilizará con fin distinto al que figure en dicho contrato, ni los comunicará, ni siquiera para su conservación, a otras personas. En el contrato se incluirán las medidas de seguridad adicionales estipuladas por el Reglamento de la LOPD que el responsable del tratamiento está obligado a implementar.Una vez cumplida la prestación contractual, los datos de carácter personal deberán ser destruidos o devueltos al responsable del tratamiento.

ARTÍCULO 15. DERECHO DE ACCESO.

El interesado tendrá derecho a solicitar y obtener gratuitamente información de sus datos de carácter personal sometidos a tratamiento, el origen de dichos datos, así como las comunicaciones realizadas o que se prevén hacer de los mismos.

ARTÍCULO 16. DERECHO DE RECTIFICACIÓN Y CANCELACIÓN.

El responsable del tratamiento tendrá la obligación de hacer efectivo el derecho de rectificación o cancelación del interesado en el plazo de diez días.

La cancelación siempre es total, conservándose únicamente a disposición de las Administraciones públicas, Jueces y Tribunales, para la atención de las posibles responsabilidades nacidas del tratamiento, durante el plazo de prescripción de éstas. Tras el cual también será suprimido dicho contenido.

ARTÍCULO 17. PROCEDIMIENTO DE OPOSICIÓN, ACCESO, RECTIFICACIÓN O CANCELACIÓN.

Los procedimientos para ejercitar el derecho de oposición, acceso, así como los de rectificación y cancelación serán establecidos reglamentariamente. Y no se incurrirá contraprestación alguna por el ejercicio de los derechos de oposición, acceso, rectificación o cancelación.

3.2. REGLAMENTO DE DESARROLLO DE LA LOPD

Debemos entender que el Reglamento de desarrollo de la LOPD es una extensión, revisión, mejora, actualización y matización de algunos aspectos de la LOPD. Por tanto, algunos de sus artículos están destinados a introducir una serie de obligaciones que forman parte integral de la legislación y que se traduce en una serie de artículos de interés entre los que seleccionaremos los más interesantes para la docencia de esta tercera unidad del módulo.

3.2.1. OBLIGACIONES

ARTÍCULO 88. EL DOCUMENTO DE SEGURIDAD.

Este artículo se establece en consonancia con el artículo 9 de la LOPD donde se especifica que el responsable del fichero o tratamiento elaborará un documento de seguridad que recogerá las medidas de índole técnica y organizativa acordes a la normativa de seguridad vigente que será de obligado cumplimiento para el personal con acceso a los sistemas de información. El documento deberá contener, como mínimo, los siguientes aspectos:

a) Ámbito de aplicación del documento con especificación detallada de los recursos protegidos.

b) Medidas, normas, procedimientos de actuación, reglas y estándares encaminados a garantizar el

nivel de seguridad exigido en este reglamento.

c) Funciones y obligaciones del personal en relación con el tratamiento de los datos de carácter personal incluidos en los ficheros.

d) Estructura de los ficheros con datos de carácter personal y descripción de los sistemas de información que los tratan.

e) Procedimiento de notificación, gestión y respuesta ante las incidencias.

f) Los procedimientos de realización de copias de respaldo y de recuperación de los datos en los ficheros o tratamientos automatizados.

g) Las medidas que sea necesario adoptar para el transporte de soportes y documentos, así como para la destrucción de los documentos y soportes, o en su caso, la reutilización de estos últimos.

Y según el nivel de seguridad tendrá que contener, además:

a) La identificación del responsable o responsables de seguridad.

b) Los controles periódicos que se deban realizar para verificar el cumplimiento de lo dispuesto en el propio documento.

El documento de seguridad deberá mantenerse en todo momento actualizado y será revisado siempre que se produzcan cambios relevantes en el sistema de información que pueda repercutir en el cumplimiento de las medidas de seguridad implantadas.

ARTÍCULO 80. NIVELES DE SEGURIDAD.

Las medidas de seguridad exigibles a los ficheros y tratamientos se clasifican en tres niveles: básico, medio y alto.

3.2.2. NIVELES DE SEGURIDAD

Los tres niveles que define el artículo 80 definen la columna vertebral relativa a las medidas y consideraciones de seguridad de la LOPD. Donde se establece un nivel de seguridad de acuerdo al tipo de datos personales que contenga cada fichero. Toda esta información se describe en los artículos 81 y desde el 89 al 114 en aquellos **procesos automatizados**, y desde el 105 al 114 para **los no automatizados**. No está de más recomendar esta lectura ya que resulta muy interesante tratándose de un documento aprobado en el 2008 y el sector de la ciberseguridad estaba en plena expansión. Sin embargo para facilitar el repaso de estos niveles se han resumido en la siguientes tablas, según el nivel y que pueden ser utilizadas como documento de consulta rápida.

NIVEL BÁSICO

NIVEL	TIPO DE DATOS
BÁSICO	• Afecta a todos los ficheros o tratamientos de datos de carácter personal. • Ideología, afiliación sindical, religión, creencias, origen racial, salud o vida sexual (cuando la única finalidad es realizar una transferencia dineraria a las entidades de las que los afectados sean asociados; o caso de ficheros que de forma accesoria contengan estos datos). • Grado de discapacidad o invalidez (salud) sólo para el cumplimiento de deberes públicos.
	MEDIDAS DE SEGURIDAD APLICABLES A FICHEROS Y TRATAMIENTOS AUTOMATIZADOS
	• Documento de seguridad • Régimen de funciones y obligaciones del personal • Registro de incidencias • Identificación y autenticación de usuarios • Control de acceso • Gestión de soportes • Copias de respaldo y recuperación.
	MEDIDAS DE SEGURIDAD APLICABLES A FICHEROS Y TRATAMIENTOS NO AUTOMATIZADOS
	• Documento de seguridad • Régimen de funciones y obligaciones del personal • Registro de incidencias. • Control de acceso. • Gestión de soportes. • Criterios de archive • Dispositivos de Almacenamiento • Custodia de los soportes

NIVEL MEDIO

NIVEL	TIPO DE DATOS
MEDIO	• Infracciones administrativas o penales • Prestación de servicios de información sobre solvencia patrimonial y crédito • Cumplimiento o incumplimiento de obligaciones dinerarias • Administraciones Tributarias • Prestación de servicios financieros • Entidades Gestoras y Servicios Comunes de la Seguridad Social, en el ejercicio de sus competencias en materia de recaudación • Definición de las características o de la personalidad (evaluación del comportamiento).
	MEDIDAS DE SEGURIDAD APLICABLES A FICHEROS Y TRATAMIENTOS AUTOMATIZADOS
	• Incluir todas las medidas de seguridad de nivel básico • Responsable de Seguridad • Auditoría • Medidas adicionales de Identificación y autenticación de usuarios (límite reintentos de acceso) • Control de acceso físico • Medidas adicionales de gestión de soportes (registro entrada y salida) • Registro de incidencias (anotación y autorización para los procedimientos de recuperación)
	MEDIDAS DE SEGURIDAD APLICABLES A FICHEROS Y TRATAMIENTOS NO AUTOMATIZADOS
	• Incluir todas las medidas de seguridad para tratamientos no automatizados de nivel básico • Responsable de Seguridad • Auditoría

NIVEL ALTO

NIVEL	TIPO DE DATOS
ALTO	• Ideología, afiliación sindical, religión, creencias, origen racial, salud o vida sexual • Fines policiales sin consentimiento • Actos de Violencia de género • Operadores de servicios de comunicaciones electrónicas (datos de tráfico y de localización).
	MEDIDAS DE SEGURIDAD APLICABLES A FICHEROS Y TRATAMIENTOS AUTOMATIZADOS
	• Incluir todas las medidas de seguridad de nivel básico y medio • Seguridad en la distribución de soportes (cifrado) • Registro de accesos (tanto para ficheros automatizados como en soporte papel) • Medidas adicionales de copias de respaldo (copia en lugar diferente) • Cifrado de telecomunicaciones • Almacenamiento de ficheros no automatizados o en papel bajo llave y en áreas de acceso restringido
	MEDIDAS DE SEGURIDAD APLICABLES A FICHEROS Y TRATAMIENTOS NO AUTOMATIZADOS
	• Incluir todas las medidas de seguridad para tratamientos no automatizados de nivel medio • Almacenamiento de la Información • Copia o reproducción • Acceso a la documentación • Traslado de documentación

3.2.3. INFRACCIONES Y SANCIONES

La LOPD también establece una serie de niveles diferenciadores respecto a las infracciones que pueden cometer los Responsables de los ficheros que contengan datos de carácter personal. Estas se clasifican en leves, graves y muy graves, atendiendo a la infracción cometida.

Cada tipo de infracción tiene una sanción económica asociada, cuyo régimen sancionador actualizó y elevó para aumentar las cuantías sancionadoras respecto a la LOPD. Mientras que esta información no es clave para aumentar nuestro conocimiento de seguridad, sí ayudará a hacernos una idea del riesgo que conllevaba hacer caso omiso de la legislación vigente en materia de protección de datos. Con la llegada del RGPD primero y el LOPDGDD aún manteniéndose estos niveles, las cuantías han cambiado sustancialmente, por lo que estas sanciones tienen un valor inestimable para percibir si estas sanciones y su efecto castigador o rectificador son suficientemente disuasorias.

LEVES (Sanciones entre 900€ y 40.000 €)

1. No atender la solicitud del interesado de rectificación o cancelación

2. No inscribir el fichero en el RGPD

3. No informar al afectado al recoger sus datos

4. Incumplir el deber de secreto del responsable

GRAVES (Sanciones entre 40.001€ y 300.000 €)

1. Crear fichero de titularidad pública o iniciar la recogida de datos sin que la correspondiente disposición general haya sido publicada en el Boletín oficial

2. Crear fichero de titularidad privada o iniciar la recogida de datos con finalidad distinta del objeto empresarial

3. Recoger datos sin el consentimiento expreso del afectado

4. Tratar o usar los datos conculcando principios de la LOPD o del Reglamento de desarrollo de la LOPD

5. Impedir u obstaculizar ejercicio de los derechos de acceso y oposición

6. Mantener datos inexactos, o no rectificarlos o cancelarlos cuando afecte derechos de las personas

7. Vulnerar el deber de secreto sobre ficheros de nivel Medio

8. Mantener los ficheros, locales, programas o equipos incumpliendo las condiciones de seguridad del Reglamento

9. No proporcionar a la AEPD cuantos documentos sean requeridos u obstruir la inspección 10. No inscribir el fichero en el RGPD, cuando haya sido requerido por la AEPD

MUY GRAVES (Sanciones entre 300.001€ y 600.000 €)

1. Recoger datos en forma engañosa y fraudulenta

2. Comunicar o ceder datos, fuera de los casos en que esté permitido

3. Recabar y tratar datos especialmente protegidos sin consentimiento del afectado o excepción LOPD

4. No cesar el uso o tratamiento ilegítimo de datos tras requerimiento de la AEPD o del afectado

5. Transferencia temporal o definitiva de datos a países no homologados sin autorización

de la AEPD

6. Tratar datos de forma ilegítima o con menosprecio de principios y garantías, cuando se impida o se atente el ejercicio de derechos fundamentales

7. Vulnerar el deber de secreto sobre datos especialmente protegidos o de nivel Alto

8. No atender u obstaculizar sistemáticamente el ejercicio de derechos de acceso, rectificación, cancelación y oposición

9. No atender sistemáticamente el deber de notificación al afectado de la inclusión en un fichero

3.3. REGLAMENTO GENERAL DE PROTECCIÓN DE DATOS

Tal y como mencionamos antes, el RGPD entró en vigor el 25 de mayo de 2016 y fue de aplicación el 25 de mayo de 2018, esto permitió a las empresas adaptarse al nuevo cumplimiento normativo y legislativo durante dos años, un período de concesión amable, donde múltiples campañas promovidas por las administraciones alertaban de los posibles efectos de no estar preparados para el RGPD y que teóricamente deberían de haber funcionado, aunque casi un año después hemos visto el poco calado que tuvieron en la práctica.

El RGPD europeo se aplicó en España de manera simultánea al resto de normas en materia de protección de datos, es decir, la prioridad hasta diciembre del 2018 la ha marcado y definido el RGPD, hasta la publicación del LOPDGDD. Por tanto la regulación en España queda estipulada por esta ley junto a todas las revisiones, recomendaciones y resoluciones judiciales que la extiendan de ahora en adelante. La comisión europea concedió este plazo a los estados miembros, dándoles tiempo para actualizar todas sus normativas y establecer un nuevo marco legislativo, bajo el paraguas de la RGPD, pero que fuese más coherente con las disposiciones nacionales, si las hubiese.

Esto aplicado a España significa que la LOPDGDD actualiza la LOPD, su reglamento y todos sus añadidos a una nueva versión, posterior al RGPD y que precisa claramente y complementa todos aquellos aspectos relativos al alcance, necesarios para la legislación española.

El RGPD actual se basa en la Directiva 95/46/CE que regulaba la protección de datos en los estados miembros. Al ser una directiva implicaba solo una hoja de ruta para los países de la Unión Europea, dejando mucho margen de actuación a los diferentes países. Sin embargo, el nuevo reglamento es de aplicación directa, sin que sea necesario ningún trámite previo de adaptación. Su contenido es ley con todas sus consecuencias y en todo el territorio Europeo sometido a la legislación de la Comisión Europea.

3.3.1. OBLIGACIONES

1. CONCIENCIACIÓN

Antes de comenzar a describir las obligaciones que trae el RGPD, ya nos pone en modo alerta. Este reglamento introduce importantes multas de hasta un 2% o 10 millones de euros o bien un 4% de la facturación global anual o 20 millones de euros por empresa, según sean sanciones menores o mayores. Pero esta no es la única razón por la que los responsables de las organizaciones deben estar al tanto de la nueva norma, algunos procesos y productos tendrán que adaptarse para cumplir con el reglamento, lo que incurrirá en costes, una correcta replanificación y unos plazos que podrían suponer un verdadero varapalo para las empresas.

Los responsables de la toma de decisiones y las personas clave en la organización deben ser conscientes de cómo les afecta la llegada del RGPD, y para apreciar el impacto tendrán que identificar las áreas que necesitan adecuarse y si el tratamiento y gestión de riesgos es el adecuado respecto a las nuevas restricciones y obligaciones impuestas.

2. TRATAMIENTO DE DATOS

Resulta fundamental revisar y verificar qué datos personales posee la empresa, de dónde vinieron y con quién se comparten. Es posible que sea necesario realizar una auditoría de información en toda la organización o dentro de áreas específicas que realicen tratamiento de datos, como las comerciales. El RGPD requiere que mantengamos registros de todas las actividades de procesamiento. Algo fundamental no sólo para garantizar que tenemos los datos de los usuarios actualizados sino también para cumplir con el principio de responsabilidad del RGPD, que requiere que las organizaciones sean capaces de demostrar cómo cumplen con los principios de protección de datos al contar con políticas y procedimientos efectivos.

El RGPD ahonda incluso en detalles sobre nuevos elementos que pasan a ser considerados datos personales, incluyendo por ejemplo el “número de identificación, datos de localización, un identificador online” etc. Esto es una consideración de primer orden, ya que esto incluye IDs de sesión, de cookies, de perfiles publicitarios, etc.

3. POLÍTICAS DE PRIVACIDAD

Al recolectar datos personales, la RGPD obliga a proporcionar a los usuarios cierta información, relativa al uso que se va a realizar con los datos de estos usuarios, como por ejemplo, si fuese necesario conocer la identidad del individuo debería de advertirse y además se debe indicar cómo piensa utilizarse dicha información. Esto generalmente se hace a través de un aviso de privacidad. Pero además hay que poner en conocimiento la base legal usada para procesar los datos, los períodos de almacenamiento de los datos, el interés legítimo que ampara el tratamiento de los datos personales y también un recordatorio a los usuarios sobre su derecho a quejarse al regulador de turno si creen que hay un problema con la forma en que se manejan sus

datos. Estas acciones son parte de la transparencia defendida por el RGPD y requiere diferentes niveles de detalle dependiendo de si se obtienen los datos directamente del individuo o no. En todos los casos, el aviso deberá ser conciso, transparente, inteligible y de fácil acceso, con un lenguaje claro y sencillo.

4. CONSENTIMIENTO

El RGPD refuerza las condiciones de consentimiento en comparación con la LOPD, introduciendo un cambio importante. El consentimiento tiene que ser libre, específico, informado e inequívoco. Éste debe consistir en una declaración o una clara acción afirmativa, no admitiendo por tanto el consentimiento tácito. En algunos casos, el consentimiento habrá de ser explícito, como sucede si el responsable trate los datos para para elaborar perfiles, si trata datos sensibles o si realiza transferencias internacionales de datos. Mientras que para obtener el consentimiento se pueden usar casillas, el RGPD establece que las casillas premarcadas o la simple inacción no constituyen una forma válida de prestar el consentimiento. Además, cuando se vayan a utilizar los datos para varias finalidades, se tendrá que recabar el consentimiento para todas ellas de forma individual y bien diferenciadas. Y por supuesto, el interesado tendrá derecho a retirar su consentimiento en cualquier momento.

5. SEUDONIMIZACIÓN

La seudonimización se define como aquella información que, sin incluir los datos denominativos de un sujeto, permiten identificarlo mediante información adicional, siempre que ésta figure por separado y esté sujeta a medidas técnicas (encriptación, hashing, etc.) y organizativas destinadas a garantizar que los datos personales no se atribuyen a una persona física identificada o identificable. De esta forma se garantiza que los datos ya no están directamente vinculados a un individuo. Los datos personales que no tengan detalles de identificación directa también podrían ser seudónimos en origen, como sería un ID de cookie aleatorio que permite

que un usuario sea reconocido, pero no identificado directamente. En cualquier caso, es fundamental tener en cuenta que el RGPD establece que los datos seudonimizados siguen siendo datos personales, y, por tanto, será necesaria una legitimación para tratarlos.

6. DERECHOS

La organización debe verificar los procedimientos para garantizar que cubren todos los derechos los usuarios:

- El derecho a ser informado.
- El derecho de acceso
- El derecho de rectificación
- El derecho a supresión (derecho al olvido)

- El derecho a la limitación del tratamiento
- El derecho a la portabilidad de datos
- El derecho de oposición (derecho a la exclusión voluntaria)
- El derecho a no someterse a la toma de decisiones automatizadas, incluyendo la elaboración de perfiles.

7. PERFILES

EL RGPD aborda explícitamente el concepto de "elaboración de perfiles" y establece que sólo se podrá llevar a cabo bajo determinadas circunstancias. En ese sentido, establece el derecho de los individuos a "no ser objeto de una decisión basada únicamente en el tratamiento automatizado, incluida la elaboración de perfiles, que produzca efectos jurídicos en él o le afecte significativamente de modo similar". Por tanto, se establecen una serie de bases de legitimación para la elaboración de tales perfiles y siempre se debe dar al usuario la posibilidad de oponerse. El responsable deberá informar sobre el uso de los perfiles, la lógica que utiliza y las posibles consecuencias, además debe tener en cuenta que no se incluyan consecuencias discriminatorias que puedan surgir debido a criterios sensibles, como raza u origen étnico, opiniones políticas o creencias religiosas, estado de salud u orientación sexual.

8. SEGURIDAD DE LOS DATOS

Las brechas de seguridad pueden tener importantes consecuencias, tanto en términos reputacionales como económicos, así como producir un perjuicio incalculable relativo al contenido expuesto. Por lo tanto, debemos asegurarnos de poner en marcha todos los procedimientos que permitan detectar, informar e investigar una brecha de seguridad. El RGPD exige a los responsables del tratamiento que hayan sufrido una infracción en la que el individuo sufra algún tipo de daño, como robo de identidad o violación de la seguridad de los datos personales, notifiquen a su Autoridad de Protección de Datos en un plazo máximo de 72 horas (en caso contrario deberá ir acompañada de indicación de los motivos de la dilación).

9. PRIVACIDAD EN EL DISEÑO Y EVALUACIÓN DEL IMPACTO

Las Evaluaciones de Impacto de la Protección de datos (PIA) juegan un papel importante en la nueva normativa. El requisito de llevar a cabo una PIA se exige en situaciones de alto riesgo, por ejemplo, cuando una nueva tecnología se está desplegando o cuando se van a elaborar perfiles que afecten significativamente a los interesados. La RGPD pone énfasis en la necesidad acuciante de integrar principios de privacidad desde el diseño y por defecto en los nuevos servicios y productos liberados al mercado. Estas medidas, la PIA y la privacidad por diseño son dos de las principales novedades del RGPD en materia de prevención a la hora de proteger a los consumidores europeos.

10. DELEGADO DE PROTECCIÓN DE DATOS

El Data Protection Officer(DPO) es una figura necesaria para las entidades, empresas, instituciones o cualquier agente ocupado de cuestiones sobre protección de datos y privacidad. Uno de los criterios para decidir si es necesario designar un delegado de protección de datos atiende a que "las actividades principales del responsable o del encargado consistan en operaciones de tratamiento que, en razón de su naturaleza, alcance y/o fines, requieran una observación habitual y sistemática de interesados a gran escala". Este perfil, que debe encajar en la estructura empresarial puede ser desempeñada por un empleado o por una persona externa. Además, el RGPD establece que un grupo de empresas pueden designar un DPO siempre que sea fácilmente accesible desde cada empresa. El DPO tiene una protección especial respecto a su empleador, y la organización no puede instruirse sobre cómo llevar a cabo su trabajo

11. TRANSFERENCIAS INTERNACIONALES

A la hora de transferir datos a países fuera de la UE es necesario fundamentar dicha transferencia conforme a las bases de legitimación que recoge el RGPD. La Comisión Europea mantiene una lista con los países que proporcionan una norma de protección de datos adecuada, incluyendo el Escudo de Privacidad (Privacy Shield) entre UE y USA. Existen otras opciones, como las transferencias mediante "garantías adecuadas", que incluyen una serie de supuestos que facilitan este trámite, como las cláusulas contractuales tipo elaboradas por la Comisión o por la autoridad de control, o los códigos de conducta bajo determinadas circunstancias.

3.3.2. IMPLANTACIÓN DEL RGPD

Tras el repaso de las obligaciones más destacadas y relacionadas con la seguridad de la información, es importante entender que las empresas han tenido un período de dos años de concesión para la adecuación al RGPD y que esta implantación ha debido ser paulatina. Cualquier organización que no demuestre su pleno cumplimiento a día de hoy se expone a las millonarias sanciones que hemos indicado antes. La RGPD fundamenta sus acciones en los datos personales y sensibles, por tanto, las empresas deben comenzar por el inventario de la tipología de datos que trata, su finalidad y las obligaciones, a tenor del reglamento, que debe cumplir. A modo de repaso, resumimos el plan de adecuación al GRPD de manera muy concreta en dos fases:

IDENTIFICACIÓN DEL ESTADO ACTUAL

IDENTIFICACIÓN DEL ESTADO ACTUAL En esta fase se llevarán a cabo las actividades necesarias para identificar las obligaciones establecidas por el RGPD que no son cumplidas por la empresa o que la LOPD no aborda eficazmente. Las directrices y actividades quedarían de la siguiente forma:

- Reunión con el responsable de seguridad de los ficheros de datos y los directores de cada uno de los departamentos;
- Análisis de las obligaciones legales con respecto al RGPD y la normativa española vigente;
- Grado de cumplimiento con respecto a la LOPD y el reglamento de la LOPD;
- Identificación de normas sectoriales que pudieran ser de aplicación;
- Análisis de los procedimientos internos aprobados hasta la fecha;
- Estudio de los Ficheros de Datos
- Procesos internos en los que se tratan datos de carácter personal;
- Bases de datos que tratan datos personales;
- Sistemas utilizados para el tratamiento de datos personales;
- Plazos de conservación, cancelación y destrucción de los datos personales;
- Finalidades de los tratamientos.
- Copias de seguridad.

ADECUACIÓN

Tras la fase de localización, identificación y recogida de datos, realizando un esfuerzo de concienciación y preparación de los elementos a mejorar, procedemos con la adecuación.

- Establecer un protocolo para que los clientes autoricen explícitamente el uso de sus datos.
- Redacción de nuevas cláusulas con trabajadores: deber de secreto y contrato de confidencialidad.
- Redacción de contratos con acreedores externos que tengan acceso a datos confidenciales.
- Revisión de sistemas de información y establecimiento de canales seguros para el tráfico interno de los datos en una empresa (contraseñas, usuarios, privilegios, seguridad informática, etc.).
- Evaluación de Impacto: Análisis de Flujos de Información en la empresa, personal con autorización e identificación de brechas de seguridad
- Elaboración de checklist para evaluar el nivel de riesgo asociado a cada obligación; • Uso de software para la gestión de contraseñas, accesos y cifrado de información.
- Uso y adecuación de dispositivos hardware seguros para almacenaje y comprobación de identidad (discos externos con cifrado, pendrive para almacenar información de forma segura, archivadores con llave, autenticación biométrica, etc.
- Guías y recomendaciones que considerar en nuevos proyectos.
- En su caso, determinación del Delegado de Protección de Datos-
- Actualizar la página web a la normativa vigente en materia de privacidad y servicios de la información y la implementación del RGPD.

3.4. LEY ORGÁNICA DE PROTECCIÓN DE DATOS Y GARANTÍA DE LOS DERECHOS DIGITALES

Llegamos por tanto a la ley más reciente que deroga expresamente la LOPD y su Reglamento junto a todas las modificaciones y enmiendas realizadas antes de la llegada del RGPD. Y como indican sus disposiciones generales, el objetivo de la LOPDGDD es lograr la adaptación del ordenamiento jurídico español al RGPD y completar sus disposiciones. Para ello establece el derecho fundamental de las personas físicas a la protección de datos personales, amparado por el artículo 18.4 de la Constitución, y que se ejercerá con arreglo a lo establecido tanto en el RGPD como en esta ley orgánica.

Hay que entender que la LOPDGDD tiene una doble función, adaptar como hemos visto las estipulaciones del RGPD al derecho español, no son pocas las alusiones a éste en cada artículo. Pero también incluir, matizando y actualizando todo artículo de la anterior LOPD y su reglamento que sea útil para el contexto español, ya que a partir de ahora dejan de tener validez jurídica.

Pese a que la LOPDGDD cobra sentido a la sombra del RGPD, hay que destacar muchas novedades incluidas en dicha ley que la administración ha sabido introducir para cubrir el mayor número de elementos que hoy en día suponen un reto en cuestiones de privacidad como por ejemplo los datos de personas fallecidas, la precisión con la que se especifica el tratamiento de información crediticia o financiera, tratamientos con fines de videovigilancia o los sistemas de exclusión publicitaria.

De entre los 97 artículos, estructurados en diez títulos, repasamos aquellos más interesantes y útiles para los objetivos docentes de este curso y que son representativos del conjunto de aspectos y medidas que aborda esta ley.

3.4.1. OBLIGACIONES

ARTÍCULO 9. CATEGORÍAS ESPECIALES DE DATOS.

A tenor del artículo 9.2.a del RGPD, y para evitar situaciones discriminatorias, el solo consentimiento del afectado no bastará para levantar la prohibición del tratamiento de datos cuya finalidad principal sea identificar su ideología, afiliación sindical, religión, orientación sexual, creencias u origen racial o étnico. Y respecto a los artículos 9.2.g, 9.2.h y 9.2.i el tratamiento de datos y fundamentado por el Derecho español deberán estar amparados en una norma con rango de ley, que podrá establecer requisitos adicionales relativos a su seguridad y confidencialidad. Tal es el caso del tratamiento de datos en el ámbito de la salud cuando así lo exija la gestión de los sistemas y servicios de asistencia sanitaria y social, pública y privada, o la ejecución de un contrato de seguro del que el afectado sea parte.

ARTÍCULO 24. SISTEMAS DE INFORMACIÓN DE DENUNCIAS INTERNAS

Será lícita la creación y mantenimiento de sistemas de información a través de los cuales pueda ponerse en conocimiento de una entidad, incluso anónimamente, circunstancias, actos o conductas que pudieran resultar contrarios a la normativa general o sectorial que le fuera aplicable. Los empleados y terceros deberán ser informados acerca de la existencia de estos sistemas de información. El acceso a los datos contenidos en estos sistemas quedará limitado exclusivamente a quienes, pertenezcan o no a la entidad, desarrollen las funciones de control interno y de cumplimiento, o a los encargados del tratamiento que eventualmente se designen a tal efecto. No obstante, será lícito su acceso por otras personas, o incluso su comunicación a terceros, cuando resulte necesario para la adopción de medidas disciplinarias o para la tramitación de los procedimientos judiciales que, en su caso, procedan.

Este artículo estipula que deberán adoptarse las medidas necesarias para preservar la identidad y garantizar la confidencialidad de los datos correspondientes a las personas afectadas por la información suministrada, especialmente la de la persona que hubiera puesto los hechos en conocimiento de la entidad, en caso de que se hubiera identificado. Además, los datos de quien formule la comunicación y de los empleados y terceros deberán conservarse en el sistema de denuncias únicamente durante el tiempo imprescindible para decidir sobre la procedencia de iniciar una investigación sobre los hechos denunciados.

ARTÍCULO 34. DESIGNACIÓN DE UN DELEGADO DE PROTECCIÓN DE DATOS

Si bien el RGPD crea la figura del DPO, es la LOPDGDD quién estipula que debe existir un listado actualizado de los DPOs en activos, junto a los ceses y cambios, además todos deben poder ser contactados y localizados por medios electrónicos. De forma adicional será necesario especificar la dedicación de cada DPO, si es total o parcial.

Pero el hecho más destacado de este artículo es que se especifican explícitamente qué entidades están obligadas a tener uno, no dejando margen a la duda, y son:

a) Los colegios profesionales y sus consejos generales.

b) Los centros docentes que ofrezcan enseñanzas en cualquier nivel establecido en la legislación reguladora del derecho a la educación, así como Universidades públicas y privadas.

c) Las entidades que exploten redes y presten servicios de comunicaciones electrónicas conforme a lo dispuesto en su legislación específica, cuando traten habitual y sistemáticamente datos personales a gran escala.

d) Los prestadores de servicios de la sociedad de la información cuando elaboren a gran escala perfiles de los usuarios del servicio.

e) Las entidades incluidas en el artículo 1 de la Ley 10/2014, de 26 de junio, de ordenación, supervisión y solvencia de entidades de crédito.

f) Los establecimientos financieros de crédito.

g) Las entidades aseguradoras y reaseguradoras.

h) Las empresas de servicios de inversión, reguladas por la legislación del Mercado de Valores.

i) Los distribuidores y comercializadores de energía eléctrica y los distribuidores y comercializadores de gas natural.

j) Las entidades responsables de ficheros comunes para la evaluación de la solvencia patrimonial y crédito o de los ficheros comunes para la gestión y prevención del fraude, incluyendo a los responsables de los ficheros regulados por la legislación de prevención del blanqueo de capitales y de la financiación del terrorismo.

k) Las entidades que desarrollen actividades de publicidad y prospección comercial, incluyendo las de investigación comercial y de mercados, cuando lleven a cabo tratamientos basados en las preferencias de los afectados o realicen actividades que impliquen la elaboración de perfiles de los mismos.

l) Los centros sanitarios están legalmente obligados al mantenimiento de las historias clínicas de los pacientes.

m) Las entidades que tengan como uno de sus objetos la emisión de informes comerciales que puedan referirse a personas físicas.

n) Los operadores que desarrollen la actividad de juego a través de canales electrónicos, informáticos, telemáticos e interactivos, conforme a la normativa de regulación del juego.

o) Las empresas de seguridad privada.

p) Las federaciones deportivas cuando traten datos de menores de edad.

3.4.2. GARANTÍAS DE DERECHOS DIGITALES

Este es uno de los capítulos cuya naturaleza diverge respecto al resto de elementos contenidos en la LOPDGDD, ya que regula una serie de derechos y libertades de diversa índole sumamente interesantes y que por fin reciben un ordenamiento jurídico que ha sido demandado durante años, permitiendo que esta ley se adapte a una realidad y sociedad actual cada vez más digitalizada y que es un fiel reflejo de que pocas actividades escapan ya de poseer una componente tecnológica y que usa o presta servicios online.

Sin describir este conjunto de artículos y garantías, todas son dignas de mención al menos para resaltar que desde la aprobación de esta ley, existe un marco jurídico que las regula y que hay que tener muy en cuenta.

Artículo 79. Los derechos en la Era digital.

Artículo 80. Derecho a la neutralidad de Internet.

Artículo 81. Derecho de acceso universal a Internet.

Artículo 82. Derecho a la seguridad digital.

Los usuarios tienen derecho a la seguridad de las comunicaciones que transmitan y reciban a través de Internet. Los proveedores de servicios de Internet informarán a los usuarios de sus derechos.

Artículo 83. Derecho a la educación digital.

Artículo 84. Protección de los menores en Internet

Artículo 83. Derecho a la educación digital.

Artículo 84. Protección de los menores en Internet.

Artículo 85. Derecho de rectificación en Internet.

Artículo 86. Derecho a la actualización de informaciones en medios de comunicación digitales. Artículo 87. Derecho a la intimidad y uso de dispositivos digitales en el ámbito laboral. Artículo 88. Derecho a la desconexión digital en el ámbito laboral

Artículo 89. Derecho a la intimidad frente al uso de dispositivos de videovigilancia y de grabación de sonidos en el lugar de trabajo.

Artículo 90. Derecho a la intimidad ante la utilización de sistemas de geolocalización en el ámbito laboral.

Artículo 91. Derechos digitales en la negociación colectiva.

Artículo 92. Protección de datos de los menores en Internet.

Artículo 93. Derecho al olvido en búsquedas de Internet.

Artículo 94. Derecho al olvido en servicios de redes sociales y servicios equivalentes. Artículo 95. Derecho de portabilidad en servicios de redes sociales y servicios equivalentes.

Artículo 96. Derecho al testamento digital.

Artículo 97. Políticas de impulso de los derechos digitales.

3.4.3. REGIMEN SANCIONADOR

El RGPD arrojó bastante incertidumbre respecto al régimen sancionador, no quedaba muy claro en qué casos podría ser sancionado una entidad y por cuánta cantidad. La normativa europea contempla sanciones muy elevadas ya que, según la infracción, las multas administrativas pueden alcanzar entre 10 y 20 millones de euros, o entre el 2 y el 4% del volumen de negocio anual global. La LOPDGDD ha sido más concisa y utiliza la recurrida fórmula de clasificación entre muy grave, grave y leve para hacer una clasificación de la gravedad, sin embargo. Así mismo, establece un listado amplio y completo de las circunstancias y anomalías de cada uno de los niveles, pero por comodidad y a modo de recolección representativa de ejemplos se incluyen solo algunos de cada grupo.

LEVES

1. El incumplimiento del principio de transparencia o el derecho de información del afectado por no facilitar toda la información exigida por los artículos 13 y 14 del RGPD

2. El incumplimiento de la obligación de informar al afectado, cuando así lo haya solicitado, de los destinatarios a los que se hayan comunicado los datos personales rectificados, suprimidos o respecto de los que se ha limitado el tratamiento.

3. La falta del cumplimiento de la obligación del encargado del tratamiento de informar al responsable del tratamiento acerca de la posible infracción por una instrucción recibida de éste de las disposiciones del RGPD o de esta ley orgánica, conforme a lo exigido por el artículo 28.3 del citado reglamento

4. No publicar los datos de contacto del delegado de protección de datos, o no comunicarlos a la autoridad de protección de datos, cuando su nombramiento sea exigible de acuerdo con el artículo 37 del RGPD y el artículo 34 de esta ley orgánica.

GRAVES

1. El tratamiento de datos personales de un menor de edad sin recabar su consentimiento, cuando tenga capacidad para ello, o el del titular de su patria potestad o tutela, conforme al artículo 8 del RGPD.

2. La falta de adopción de aquellas medidas técnicas y organizativas que resulten apropiadas para aplicar de forma efectiva los principios de protección de datos desde el diseño, así como la no integración de las garantías necesarias en el tratamiento, en los términos exigidos por el artículo 25 del RGPD.

3. El incumplimiento de la obligación de designar un representante del responsable o encargado del tratamiento no establecido en el territorio de la Unión Europea, conforme a lo previsto en el artículo 27 del RGPD.

4. La falta de atención por el representante en la Unión del responsable o del encargado del tratamiento de las solicitudes efectuadas por la autoridad de protección de datos o por los afectados.

MUY GRAVES

1. La utilización de los datos para una finalidad que no sea compatible con la finalidad para la cual fueron recogidos, sin contar con el consentimiento del afectado o con una base legal para ello

2. El tratamiento de datos personales relacionados con infracciones y sanciones administrativas fuera de los supuestos permitidos por el artículo 27 de esta ley orgánica.

3. No facilitar el acceso del personal de la autoridad de protección de datos competente a los datos personales, información, locales, equipos y medios de tratamiento que sean requeridos por la autoridad de protección de datos para el ejercicio de sus poderes de investigación.

4. La reversión deliberada de un procedimiento de anonimización a fin de permitir la reidentificación de los afectados.

3.4.4. DISPOSICIONES ADICIONALES

Por último, vemos algunas disposiciones adicionales de interés para los objetivos docentes y que forman parte del conjunto de estipulaciones aprobadas con la LOPDGDD.

DISPOSICIÓN ADICIONAL UNDÉCIMA. PRIVACIDAD EN LAS COMUNICACIONES ELECTRÓNICAS.

Lo dispuesto en la presente ley orgánica se entenderá sin perjuicio de la aplicación de las normas de Derecho interno y de la Unión Europea reguladoras de la privacidad en el sector de las comunicaciones electrónicas, sin imponer obligaciones adicionales a las personas físicas o jurídicas en materia de tratamiento en el marco de la prestación de servicios públicos de comunicaciones electrónicas en redes públicas de comunicación en ámbitos en los que estén sujetas a obligaciones específicas establecidas en dichas normas.

DISPOSICIÓN ADICIONAL DECIMOSEXTA. PRÁCTICAS AGRESIVAS EN MATERIA DE PROTECCIÓN DE DATOS.

A los efectos previstos en el artículo 8 de la Ley 3/1991, de 10 de enero, de Competencia Desleal, se consideran prácticas agresivas las siguientes:

a. Actuar con intención de suplantar la identidad de la Agencia Española de Protección de Datos o de una autoridad autonómica de protección de datos en la realización de cualquier comunicación a los responsables y encargados de los tratamientos o a los interesados.

b. Generar la apariencia de que se está actuando en nombre, por cuenta o en colaboración con la Agencia Española de Protección de Datos o una autoridad autonómica de protección de datos en la realización de cualquier comunicación a los responsables y encargados de los tratamientos en que la remitente ofrezca sus productos o servicios.

c. Realizar prácticas comerciales en las que se coarte el poder de decisión de los destinatarios mediante la referencia a la posible imposición de sanciones por incumplimiento de la normativa.

d. Ofrecer cualquier tipo de documento por el que se pretenda crear una apariencia de cumplimiento de las disposiciones de protección de datos de forma complementaria a la realización de acciones formativas sin haber llevado a cabo las actuaciones necesarias para verificar que dicho cumplimiento se produce efectivamente.

e. Asumir, sin designación expresa del responsable o el encargado del tratamiento, la función de delegado de protección de datos y comunicarse en tal condición con la Agencia Española de Protección de Datos o las autoridades autonómicas de protección de datos.

DISPOSICIÓN ADICIONAL DECIMOCTAVA. CRITERIOS DE SEGURIDAD.

La Agencia Española de Protección de Datos desarrollará, con la colaboración, cuando sea precisa, de todos los actores implicados, las herramientas, guías, directrices y orientaciones que resulten precisas para dotar a los profesionales, microempresas y pequeñas y medianas empresas de pautas adecuadas para el cumplimiento de las obligaciones de responsabilidad activa establecidas en el Título IV del RGPD y en el Título V de esta ley orgánica.

4. LSSI-CE Y E-PRIVACY

La LSSI o LSSI-CE (Ley de Servicios de la Sociedad de la Información y de Comercio Electrónico) es la Ley encargada de regular aquellos sitios o plataformas web destinadas al comercio electrónico. Esta ley está pensada para proporcionar confianza a los internautas y sobre todo para consumidores que quieran realizar transacciones y pagos de forma online a través de internet. Por tanto, esta ley recoge las obligaciones de los prestadores de servicios establecidos en España y otorga una serie de garantías de seguridad a los consumidores y a los usuarios.

La Ley 34/2002, del 11 de julio o LSSI, ha sufrido varias actualizaciones, extensiones y mejoras, siendo la última del 10 de Mayo de 2014. Introduciendo una serie de cambios que responden a la evolución natural de los medios online y a las diferentes consideraciones del comercio electrónico que debían ser encajadas en un marco legal que las amparase. Con la llegada de la RGPD en 2016 y la nueva LOPDGDD, la LSSI también está en ciernes de quedar derogada por el nuevo Reglamento de Privacidad Electrónica (e-Privacy) de la Unión Europea. Que suponemos

deberá desarrollarse, al igual que la LOPDGDD, de forma adecuada a la legislación española.

4.1. LEY DE SERVICIOS DE LA SOCIEDAD DE LA INFORMACIÓN Y DE COMERCIO ELECTRÓNICO

La LSSI se aplica a distintos servicios relacionados con Internet cuando el prestador del servicio desea desempeñar una actividad económica o lucrativa, como comercio electrónico, contratación en línea, proporcionar información de forma monetizada o establecer medios publicitarios. En este sentido, se considera que existe actividad económica cuando el responsable de la página web reciba ingresos directos (por las actividades de comercio electrónico asociadas al servicio) o indirectos (ya sea por publicidad o patrocinio derivados de la actividad que realice por medios electrónicos). Por otro lado, la LSSI-CE no se aplica a las actividades realizadas sin ánimo de lucro (como las de los partidos políticos, sindicatos, asociaciones, ONGs, etc.) mientras no constituyan una actividad económica.

Para entender las implicaciones de la LSSI-CE repasamos sus obligaciones en distintos ámbitos.

OBLIGACIONES Y RESPONSABILIDADES DE LOS PRESTADORES DE SERVICIOS RELACIONADOS CON INTERNET

Identificación del prestador de servicio

La siguiente información debe ser provista por los prestadores de servicios relacionados con internet en su página web de forma permanente, fácil, directa y gratuita:

- Su nombre o denominación social y datos de contacto: domicilio, dirección de correo electrónico y cualquier otro dato que permita una comunicación directa y efectiva.
- Si la empresa está registrada en el Registro Mercantil o cualquier otro registro público, deberá señalar también el número de inscripción que le corresponda.
- En el caso en que la actividad que se ejerza precise de una autorización administrativa previa, los datos relativos a la misma y los identificativos del órgano encargado de su supervisión.
- Si se ejerce una profesión regulada, los datos del colegio profesional y el número de colegiado; el título académico y el Estado de la UE en que se expidió; la correspondiente homologación (en su caso); y los códigos deontológicos aplicables al ejercicio de su profesión.
- Su Número de Identificación Fiscal (NIF).
- Información sobre el precio de los productos, indicando si incluye o no los impuestos aplicables y los gastos de envío.
- Los códigos de conducta a los que esté adherido, en su caso, y la forma de consultarlos electrónicamente.

Responsabilidad de los prestadores de servicios.

Los prestadores de servicios deben colaborar con las autoridades competentes para retirar contenido o para interrumpir la prestación de un servicio. Los prestadores de servicios de intermediación no son, en principio, responsables por los contenidos ajenos que transmiten, alojan o a los que facilitan acceso, salvo que tomen participación activa en su elaboración. O conociendo la ilegalidad de un determinado material, no actúan con rapidez para retirarlo o impedir el acceso al mismo.

Cookies

Cuando los prestadores de servicios relacionados con Internet empleen cookies deben recabar el consentimiento de los usuarios después de que los mismos hayan sido informados de manera clara y completa sobre su utilización y finalidad. Aunque existe una excepción para aquellas cookies necesarias para la prestación de un servicio de la sociedad de la información expresamente solicitado por el destinatario. Por ejemplo, las cookies de autenticación para identificar al usuario una vez registrado, o el carrito de la compra en una página de internet donde se van almacenando los artículos que vamos comprando antes de proceder al pago final.

Información sobre seguridad

Los proveedores de acceso a Internet están obligados a informar a sus usuarios sobre los medios técnicos que permitan la protección frente a las amenazas de seguridad en Internet (virus informáticos, ransomware, spyware, adware, etc.) y sobre las herramientas para el filtrado de contenidos no deseados. Así como informar de las medidas de seguridad que ellos mismos aplican en la provisión de sus servicios.

OBLIGACIONES PARA LA CONTRATACIÓN ELECTRÓNICA

La LSSI-CE asegura la validez y eficacia de los contratos que se celebren por vía electrónica, aunque no consten, a su vez, en soporte papel. Cualquier tipo de contrato puede celebrarse por vía electrónica salvo los relativos al Derecho de familia y sucesiones (por ejemplo, un testamento).

Antes de iniciar el procedimiento de contratación el prestador de servicios, deberá poner a disposición del usuario de forma permanente, fácil y gratuita, que además debe realizarse de forma clara, comprensible e inequívoca, la siguiente información:

- Las condiciones generales de contratación que, en su caso, rijan el contrato.
- Los trámites o pasos que debe seguir para celebrar el contrato.
- Si va a archivar el documento electrónico del contrato y si va ser accesible.
- Los medios técnicos que pone a su disposición para identificar y corregir los errores en la

introducción de los datos antes de confirmarlos.

- La lengua o lenguas en las que puede formalizarse el contrato.

Tras la celebración del contrato:

- Confirmar la recepción de la aceptación por alguno de los siguientes medios:
    - Por medio de un acuse de recibo por correo electrónico u otro medio de comunicación electrónica equivalente.
    - Por medio de un medio equivalente al que se haya utilizado en la contratación.

OBLIGACIONES PARA LA PUBLICIDAD ONLINE

La publicidad debe presentarse como tal, de manera que no pueda confundirse con otra clase de contenido, e identificarse de forma clara al anunciante. En casos como las ofertas promocionales (es decir, aquellas que incluyen regalos o premios o descuentos y concursos o juegos promocionales) deben cumplir, además, las condiciones de acceso y participación, y éstas deben ser fácilmente accesibles y expresadas de forma clara e inequívoca.

Sobre los envíos de comunicaciones comerciales (por ejemplo, una newsletter con novedades comerciales) el usuario deberá haberlo solicitado o autorizado expresamente con carácter previo. No obstante, se permite el envío de comunicaciones comerciales a aquellos usuarios con los que ya exista una relación contractual previa, en cuyo caso el proveedor podrá enviar publicidad sobre productos o servicios similares a los contratados por el cliente. Si bien, el prestador debe ofrecer la posibilidad al destinatario de oponerse al tratamiento de sus datos con estos fines.

4.2. E-PRIVACY

El Reglamento de e-Privacy será de aplicación directa en todos los Estados miembros y su objetivo principal consiste en complementar el RGPD, estableciendo la regulación de la protección de los datos y la privacidad en las comunicaciones electrónicas, quedando claramente definido que ese es el ámbito de actuación de e-Privacy.

Este reglamento basa sus ámbitos de actuación en tres frentes:

- Protección para los usuarios particulares, ya que el contenido de las comunicaciones puede desvelar información personal, de salud, de preferencia sexual, política etc.
- Protección para las empresas, ya que puede revelar información sobre personas jurídicas, secretos industriales o comerciales, documentos confidenciales, etc.
- Metadatos, que son los datos tratados en una red de comunicaciones electrónicas con el fin de transmitir, distribuir o intercambiar contenido de comunicaciones electrónicas, y habitualmente son generados durante la comunicación, como la hora de conexión, la

ubicación, duración de la comunicación, tipo de comunicación, etc.

Este reglamento aún no ha sido aprobado finalmente, pero podemos presentar sus principales novedades como preámbulo de las consideraciones obligatorias que supondrá su activación.

4.2.1. NOVEDADES

1. EL CONSENTIMIENTO

El reglamento e-Privacy, al igual que la RGPD, introduce un consentimiento más estricto para la publicidad digital, que debe estar en consonancia a las bases legales de este. Es decir, se aplica también que la manifestación de voluntad por la que el interesado acepta el tratamiento de sus datos, debe producirse mediante una declaración o una clara acción afirmativa.

Este consentimiento debe ser, al igual que en el RGPD, libre, específico, informado e inequívoco.

2. E-MAIL MARKETING

Este es uno de los factores más influenciados por las nuevas características de consentimiento, por lo tanto, la publicidad digital asociada al marketing vía e-mail debe también exigir a los consumidores su consentimiento. Y marcado por el RGPD, la persona física o jurídica que envíe las comunicaciones deberá cumplir unos requisitos formales de identificación y asunción de responsabilidades.

3. LAS COOKIES

El nuevo reglamento de e-Privacy afecta a las cookies pero también a las direcciones IP, y en general, a cualquier elemento que sirva para rastrear a un usuario, ya sea con fines comerciales o no. Este propone dejar de lado los avisos informativos de las webs de aceptación de cookies y obtener el consentimiento a través del navegador, eligiendo la configuración de privacidad. Por tanto, delega y traspasa a los navegadores ciertas responsabilidades respecto a las capacidades de los usuarios de revisar sus opciones de configuración. Convirtiendo al navegador además en un área de protección de la identidad y datos del perfil de usuario.

4. AD BLOCKERS

Un ad blocker es un software que permite “bloquear” la visualización de anuncios durante la navegación. E-Privacy no regula específicamente el uso de ad-blockers pero sí habilita a los propietarios de sitios web a comprobar si el navegador del usuario puede recibir su contenido, ya que los anuncios son la fuente principal de ingresos de determinados servicios online. Por tanto, los usuarios serán informados de que los anuncios están siendo bloqueados por los ad-blockers para preguntar si están dispuestos a pagar dicho software de protección durante la navegación.

5. INTERNET DE LAS COSAS

Respecto a los dispositivos conectados y el Internet de las Cosas, se establece la necesidad de transparencia e información con avisos destacados sobre el uso de los datos. La idea es mejorar la transparencia y que los usuarios sepan en todo momento el tratamiento que se está haciendo con sus datos y la localización de los mismos.

6. RÉGIMEN SANCIONADOR

El régimen sancionador establece unas multas similares al del RGPD de hasta un 4% del volumen de negocios mundial anual o hasta un máximo de 20 millones de euros

5. NORMATIVAS DE INTERÉS

Las siguientes normativas y leyes, pese a que en determinados sectores y ámbitos adquieren gran relevancia no las abordaremos en detalle. Las describiremos brevemente para entender sus objetivos y que estos extractos sirvan de base para ampliar conocimientos.

5.1. LEY DE PROTECCIÓN INTELECTUAL (LPI)

La ley de protección intelectual se basa en el Real Decreto Legislativo 1/1996, del 12 de abril, y proporciona al autor de una obra científica, literaria, artística o didáctica protección por su creación intelectual. De forma que el autor podrá exponerla o reproducirla por cualquier medio, traducirla, explotarla comercialmente o autorizar a otros a hacerlo. También le permite impedir que cualquier persona no autorizada ejerce estos derechos.

Ejemplos de elementos y obras que están cubiertas por esta ley son entre otras: libros y otros escritos; obras dramáticas; dibujos, pinturas, esculturas y obras de arquitectura; planos, mapas y maquetas; obras cinematográficas y audiovisuales; emisiones de radiodifusión; fotos; composiciones musicales, grabaciones y fonogramas; coreografías; programas de computación; bases de datos; etc.

Hay que entender que la ley protege también a los colaboradores, herederos del autor, los que adaptan o modifican la obra con permiso del autor y para el caso del software las empresas o personas que elaboran software basado en otro software protegido. Además, el derecho de propiedad intelectual tiene diferentes períodos de validez. El autor estará protegido durante toda su vida, mientras que para el resto de individuos o empresas protegidas los períodos cambian de acuerdo a la naturaleza de la obra.

Esta ley ha sufrido numerosas modificaciones para ampliar o reducir las consideraciones de protección y explotación sobre derechos de autor. A veces inclusiones polémicas como la **tasa google**, que es una imposición al pago de una remuneración a los prestadores de servicio

electrónicos de agregación de contenidos, tasa que parece creada ex profeso para gravar la actividad del famoso buscador por los actos de puesta a disposición del público de pequeños fragmentos de información procedente de noticiarios y periódicos. Aun así, es innegable que es una ley muy dinámica, cuya última revisión data de abril de 2018.

5.2. ESQUEMA NACIONAL DE SEGURIDAD (ENS)

El Esquema Nacional de Seguridad (ENS), regulado por el Real Decreto 3/2010, de 8 de enero, determina la política de seguridad que se ha de aplicar en la utilización de los medios electrónicos de las Administraciones Públicas. El ENS está constituido por los principios básicos y requisitos mínimos para una protección adecuada de la información. Será aplicado para asegurar el acceso, integridad, disponibilidad, autenticidad, confidencialidad, trazabilidad y conservación de los datos, informaciones y servicios utilizados en medios electrónicos que gestiones en el ejercicio de sus competencias.

El ENS genera las condiciones necesarias de confianza en el uso de los medios electrónicos, a través de medidas para garantizar la seguridad de la información y los servicios electrónicos, que permita a los ciudadanos y a las Administraciones Públicas, el ejercicio de derechos y el cumplimiento de deberes a través de estos medios. Para ello establece la política de seguridad en la utilización de medios electrónicos, que estará constituida por los principios básicos y los requisitos mínimos para una protección adecuada de la información.

Adicionalmente los principales objetivos persiguen lo siguiente:

- Introducir los elementos comunes que han de guiar la actuación de las Administraciones públicas en materia de seguridad de las tecnologías de la información.
- Aportar un lenguaje común para facilitar la interacción de las Administraciones públicas, así como la comunicación de los requisitos de seguridad de la información a la Industria.
- Aportar un tratamiento homogéneo de la seguridad que facilite la cooperación en la prestación de servicios de administración electrónica cuando participan diversas entidades.
- Facilitar un tratamiento continuado de la seguridad.

La reciente LOPDGDD establece en sus disposiciones adicionales, nueva información relativa al ENS donde estipula que éste debe incluir las medidas que deban implantarse en caso de tratamiento de datos personales para evitar su pérdida, alteración o acceso no autorizado, adaptando los criterios de determinación del riesgo en el tratamiento de los datos a lo establecido en el artículo 32 del RGPD

Los responsables enumerados en el artículo 77.1 de la LOPDGDD deberán aplicar a los tratamientos de datos personales las medidas de seguridad que correspondan de las previstas en

el ENS, así como impulsar un grado de implementación de medidas equivalentes en las empresas o fundaciones vinculadas a los mismos sujetas al Derecho privado. En los casos en los que un tercero preste un servicio en régimen de concesión, encomienda de gestión o contrato, las medidas de seguridad se corresponderá con las de la Administración pública de origen y se ajustarán al ENS.